

BÁO CÁO ĐỒ ÁN

MINI VAULT

Secure Storage và Encryption/Signing as a Service

Thành viên	MSSV	Đóng góp chính
Lê Công Tuấn	_____	Core Vault, tích hợp, Transit hoàn chỉnh, security review, kiểm thử và đóng gói
Nguyễn Tuấn An	_____	Authentication, Session, KV Engine và KV ownership
Trần Thọ	_____	Test framework, ciphertext parser và kế hoạch kiểm thử

Môn học: An ninh máy tính

Ngày hoàn thiện kỹ thuật: 27/07/2026

LƯU Ý TRƯỚC KHI NỘP: điền đúng MSSV, đổi tên PDF/ZIP theo đề và quay video demo 3-5 phút.

TÓM TẮT ĐIỀU HÀNH

Mini Vault là dịch vụ FastAPI chạy local, kết hợp hai mục tiêu bắt buộc của đề bài: KV Engine lưu trữ bí mật được mã hóa tại rest và Transit Engine thực hiện mã hóa, giải mã, ký số, xác minh mà không xuất khóa bí mật ra client. Hệ thống sử dụng Argon2id, AES-256-GCM, SHA-256 và ED25519; danh tính luôn được lấy từ session token thay vì tin dữ liệu owner do client gửi.

Bản hoàn thiện đã được kiểm tra bằng 58 automated tests, chạy ở chế độ warnings-as-errors và đạt statement coverage 96%. Test bao phủ restart/lock, wrong passphrase, lockout, token expiry, ciphertext-at-rest, tamper detection, cross-user denial, named key lifecycle, revoked key, wrong usage, malformed ciphertext, RAW/DIGEST sign-verify và end-to-end flow.

1. PHẠM VI VÀ YÊU CẦU ĐỀ BÀI

1.1 Mục tiêu thành công

- Dữ liệu lưu trên đĩa luôn ở dạng ciphertext, không lưu plaintext secret hoặc plaintext private key.
- Chỉ chủ sở hữu hợp lệ mới đọc/ghi KV và sử dụng named key.
- AES key và ED25519 private key không rời server qua bất kỳ API response nào.

1.2 Ma trận rubric và bảng chứng

Mục	Điểm	Yêu cầu chính	Bảng chứng triển khai/test
0.1	1.00	Init/Unlock; Argon2id; DEK random; AES-GCM wrap; restart locked	src/core/*; tests/test_core.py
0.2	1.00	Register/Login; Argon2 password; token expiry; 5 sai/5 phút	src/auth/*; tests/test_auth.py
1.1	1.25	KV AEAD at rest; tamper detection; không lộ plaintext	src/kv/*; tests/test_kv.py
1.2	1.00	Token email khớp secret/<email>/...; cross-user denied	paths.py, dependencies.py; cross-user tests
2.1	1.00	Named AES key; encrypted material; list không trả key	transit repository/service; test_transit_keys.py
2.2	1.25	Encrypt/Decrypt; định dạng vault:...; malformed/tamper/revoked	ciphertext.py; test_transit_crypto.py
2.3	1.00	Named-key ownership trước unwrap; không lộ key tồn tại	_owned_key(); cross-user tests
2.4	1.00	ED25519; RAW/DIGEST; verify false khi sửa/cross-key	TransitService sign/verify; test_sign_verify.py
Tài liệu	0.75	README, report, phân công	README.md; docs/*
Demo	0.75	Video 3-5 phút	docs/DEMO_SCRIPT.md

2. KIẾN TRÚC HỆ THỐNG

Client -> FastAPI Routes -> Authentication/Authorization -> Services -> Repositories -> SQLite + JSON Config

Kiến trúc phân lớp giúp tách validation/API contract khỏi nghiệp vụ, tách nghiệp vụ khỏi persistence, đồng thời giới hạn vùng mã được phép truy cập DEK hoặc key material. FastAPI lifespan khởi tạo schema database và ép Vault trở về locked mỗi lần process bắt đầu.

Lớp/Module	Trách nhiệm	Ranh giới bảo mật
src/api	Schema, route, dependency injection	Không giữ key; không tự quyết định owner
src/auth	Password, login, session, lockout	DB lưu password hash và token hash
src/core	Init, unlock, DEK lifecycle, crypto primitive	DEK plaintext chỉ tồn tại trong RAM khi unlocked
src/kv	KV write/read/delete, ownership, audit	Owner check trước Vault-state/crypto
src/transit	Named key, encrypt/decrypt, sign/verify	Private material được DEK wrap; không export
src/storage	Atomic config và SQLite schema	Rollback khi lỗi; foreign key và indexes

3. VAULT CORE - INIT, UNLOCK VÀ KEY HIERARCHY

3.1 Khởi tạo

1. Kiểm tra Vault chưa được khởi tạo và Master Passphrase đạt tối thiểu 12 ký tự.
2. Sinh salt 16 byte bằng CSPRNG và dẫn xuất wrapping key 32 byte bằng Argon2id.
3. Sinh DEK 256 bit ngẫu nhiên.
4. Dùng AES-256-GCM để mã hóa DEK với AAD cố định mini-vault:dek-wrap:v1.
5. Ghi config theo chiến lược temporary file + fsync + atomic replace.
6. Kết thúc init ở trạng thái locked; DEK không được giữ lại trong runtime.

3.2 Unlock và restart behavior

Unlock dẫn xuất lại wrapping key từ passphrase và salt đã lưu. Sai passphrase hoặc config bị sửa đều dẫn đến GCM authentication failure và được chuẩn hóa thành UNLOCK_FAILED; phản hồi không tiết lộ nguyên nhân là passphrase sai hay ciphertext/tag bị tamper. Khi process restart, VaultState mới không có DEK, vì vậy trạng thái mặc định luôn locked.

3.3 Key hierarchy

Master Passphrase --Argon2id--> Wrapping Key --AES-GCM unwrap--> DEK
 DEK --AES-GCM unwrap--> Named AES Key / ED25519 Private Key
 Named AES Key --AES-GCM--> Transit Ciphertext

4. AUTHENTICATION VÀ SESSION

User passphrase được Argon2id hash với salt và tham số nhúng trong encoded hash. Login trả một token ngẫu nhiên URL-safe; database chỉ lưu SHA-256 hash của token. Dependency HTTP Bearer kiểm tra token tồn tại, chưa revoke và chưa hết hạn trước khi tạo AuthenticatedUser.

Tình huống	Phản ứng	Mục đích
Email không tồn tại hoặc password sai	INVALID_CREDENTIALS	Không tạo user-enumeration oracle
5 lần đăng nhập sai	Khóa 5 phút	Giảm brute-force online
Lockout đã hết hạn	Reset failed_attempts rồi mở cửa sổ mới	Không khóa lại ngay ở lần sai tiếp theo
Token thiếu/sai/hết hạn/revoke	UNAUTHENTICATED	Không vào service nghiệp vụ
Logout	Ghi revoked_at cho token hash	Thu hồi session trước expiry

5. KV ENGINE - ENCRYPTED AT REST

5.1 Luồng ghi

Bearer token -> requester_email -> authorize path -> require Vault unlocked -> JSON serialize -> AES-GCM(DEK, AAD owner+path) -> SQLite UPSERT

Path bắt buộc có dạng secret/<email>/<name>. Owner không lấy từ request body mà lấy từ token đã xác thực. AAD gán cả owner và path, ngăn ciphertext bị sao chép sang chủ sở hữu hoặc path khác mà vẫn giải mã được.

5.2 Luồng đọc và xóa

Hệ thống kiểm tra ownership trước trạng thái Vault. Quyết định này ngăn user không có quyền dùng trạng thái locked/unlocked làm side channel để suy đoán tài nguyên người khác. Read xác minh GCM tag; sai Base64, tag hoặc ciphertext trả TAMPER_DETECTED. Delete dùng khóa owner_email + path và không giữ version cũ.

5.3 Audit

Truy cập bị từ chối được ghi requester_email, action, target type/identifier, result và thời gian. AuditRepository không nhận password, bearer token, plaintext secret, AES key hoặc private key.

6. TRANSIT ENGINE - NAMED KEY MANAGEMENT

Hai loại named key được hỗ trợ: ENCRYPT_DECRYPT cho AES-256-GCM và SIGN_VERIFY cho ED25519. Mỗi key được định danh duy nhất theo (owner_email, key_name). Tên key chỉ cho phép chữ, số, dấu chấm, gạch dưới và gạch ngang để tránh parser ambiguity.

Operation	Điều kiện	Dữ liệu trả về
Create AES key	Vault unlocked; tên hợp lệ; chưa trùng	Metadata, không có key material
Create signing key	Vault unlocked; algorithm ED25519	Metadata, không có private key
List	Token hợp lệ	key_name, usage, algorithm, created_at, revoked
Revoke	Đúng owner; key active; Vault unlocked	Metadata revoked=true

AES key và ED25519 private key được mã hóa dưới DEK bằng AES-GCM. AAD chứa owner, key_name, key_usage và signing_algorithm, vì vậy sửa metadata hoặc chuyển key sang record khác làm unwrap thất bại. Public key ED25519 được phép lưu rõ vì không phải bí mật.

7. TRANSIT ENCRYPT/DECRYPT

7.1 Ciphertext contract

vault:<key_name>:<base64(nonce || ciphertext || tag)>

Nonce AES-GCM dài 12 byte, tag dài 16 byte. Parser chỉ chịu trách nhiệm framing; xác thực tamper thật sự diễn ra khi AES-GCM decrypt. Malformed prefix, thiếu phần, Base64 hỏng hoặc payload quá ngắn bị từ chối bằng lỗi ổn định.

7.2 Thứ tự kiểm tra bảo mật

- Parse định dạng để lấy key_name.
- Tra cứu theo đúng (owner_email, key_name). Missing và foreign key dùng cùng PERMISSION_DENIED để không lộ tồn tại.
- Kiểm tra revoked và key_usage.
- Yêu cầu Vault unlocked.
- Unwrap named key bằng DEK và thực hiện AES-GCM encrypt/decrypt.

Plaintext đi qua API ở dạng Base64 để hỗ trợ text, JSON hoặc binary. Output decrypt cũng trả plaintext_b64, tránh giả định encoding của client.

8. SIGN VÀ VERIFY

Signing key sử dụng ED25519. Private key Raw 32 byte được mã hóa bởi DEK; public key Raw 32 byte được lưu để verify. API yêu cầu signing_algorithm khớp ED25519, key_usage đúng SIGN_VERIFY và key chưa revoke.

message_type	Xử lý trước ký/xác minh	Validation
RAW	Decode Base64 rồi SHA-256(message)	Mọi độ dài message hợp lệ
DIGEST	Dùng trực tiếp bytes đầu vào	Bắt buộc đúng 32 byte SHA-256 digest

Message bị sửa hoặc dùng public key khác làm ED25519 verify thất bại và trả signature_valid=false. Signature Base64 sai hoặc sai độ dài không làm server crash; verify trả false theo hợp đồng an toàn.

9. API VÀ ERROR CONTRACT

Nhóm	Endpoint chính
Core	GET /health; GET status; POST init/unlock/lock
Auth	POST register/login/logout
KV	POST/GET/DELETE /v1/kv/entries
Transit key	POST keys; POST signing-keys; GET keys; POST revoke
Transit crypto	POST encrypt/decrypt/sign/verify

Error handler tập trung ánh xạ exception nội bộ sang mã HTTP và JSON {error, message}. Không trả stack trace, passphrase, key material, GCM detail hoặc thông tin phân biệt missing key với foreign key.

10. KIỂM THỬ VÀ KẾT QUẢ

```
python -m pytest -q -W error
python -m compileall -q main.py src tests
python -m coverage run -m pytest -q
python -m coverage report -m
```

Chỉ số	Kết quả
Automated tests	58 passed
Warnings-as-errors	Passed
Compileall	Passed
Statement coverage	96%
OpenAPI smoke check	Đủ Core, Auth, KV, Transit, Sign/Verify

10.1 Nhóm test trọng yếu

- Core: init/restart/locked, wrong passphrase, tampered wrapped DEK, không lưu plaintext DEK.
- Auth: register, duplicate, password hash, login, expiry, revoke, 5-failure lockout và expiry reset.
- KV: round-trip, overwrite, delete, not-found, ciphertext-at-rest, tampered tag, cross-user read/write/delete, authorization-before-lock.
- Transit: key create/list/revoke, encrypted key material, wrong usage, malformed/truncated/tampered ciphertext, cross-user key denial.
- Sign/Verify: RAW, DIGEST, invalid digest length, modified message, cross-key, malformed signature, revoked key.
- End-to-end: init -> unlock -> register/login -> KV -> Transit encrypt/decrypt -> Sign/Verify.

11. PHÂN TÍCH BẢO MẬT THEO CIA

Thuộc tính	Biện pháp	Bằng chứng
Confidentiality	AEAD at rest; key hierarchy; token hash; không export key	DB/config scan và API response tests
Integrity	GCM tag + contextual AAD; ED25519 signature	Tamper config/KV/transit và modified-message tests
Availability	Lockout có thời hạn; SQLite busy timeout/rollback; generic errors	Expiry-reset tests; transaction behavior

11.1 Threat reflection

Nguy cơ	Kiểm soát hiện có	Residual risk
Brute-force password	Argon2id + 5 lần sai/5 phút	Rate limiting nên đặt thêm ở reverse proxy
DB bị lấy cắp	Secret/key material ciphertext; token hash	Metadata và public key vẫn nhìn thấy
IDOR/cross-user	Identity từ token; query theo owner; generic denial	Cần duy trì test khi thêm endpoint
Tamper dữ liệu	AES-GCM tag và AAD	DoS vẫn có thể xảy ra nếu file bị phá
Memory disclosure	DEK chỉ runtime; best-effort overwrite	Python không bảo đảm zeroization tuyệt đối
Network sniffing	Demo local	Production cần TLS/reverse proxy

12. PHÂN CÔNG, TÍCH HỢP VÀ CHANGE HISTORY

Thành viên	Phần đã thực hiện	Trạng thái cuối
Lê Công Tuấn	Core, integration, Transit completion, Sign/Verify, security review, regression, docs/package	Done
Nguyễn Tuấn An	Authentication, Session, KV Engine, KV ownership	Done; được tích hợp và bổ sung regression

Thành viên	Phần đã thực hiện	Trạng thái cuối
Trần Thọ	Shared test framework, test matrix, ciphertext parser	Done; được recovery vào main

Change reflection: sau khi hai feature branch của Trần Thọ lệch khỏi main, nhóm không merge trực tiếp mà recovery đúng commit lên nhánh integration mới, chạy regression rồi merge. Khi hai thành viên bận, Lê Công Tuấn tiếp quản các phần còn thiếu theo critical path: Named Key -> Encrypt/Decrypt -> Ownership -> Sign/Verify -> End-to-end -> Docs/Package. Việc tiếp quản không thay đổi phạm vi đề bài, chỉ thay đổi owner thực thi.

13. REFLECTION CHECK VÀ HẠN CHẾ

13.1 Reflection đã đóng

- Yêu cầu 0.1-2.4 đều có implementation evidence và automated test evidence.
- Hai lỗi integration quan trọng đã được xử lý: lockout expiry reset và authorization trước Vault-state check.
- README cũ chỉ mô tả Core đã được thay bằng tài liệu toàn hệ thống.
- Không thêm feature ngoài phạm vi như UI, cloud deployment hay key export.

13.2 Hạn chế còn lại

- Dịch vụ demo local chưa cấu hình TLS, reverse proxy, rate limiting hoặc WAF.
- SQLite phù hợp đồ án/local nhưng không phải lựa chọn cho multi-instance write-heavy.
- Python memory zeroization chỉ là best-effort.
- Video demo và điền MSSV vẫn là thao tác thủ công của nhóm.

14. KẾT LUẬN

Mini Vault hoàn thành hai mục tiêu của đề: secure KV storage và cryptographic transit service. Thiết kế chứng minh ba tiêu chí trọng tâm bằng cả code và test: dữ liệu persistence là ciphertext, owner enforcement được áp dụng trước crypto/key unwrap, và encryption/signing private key không rời server. Bản source đã qua 58 tests, compile check và coverage 96%; phần còn lại trước nộp là điền MSSV, xuất PDF đúng tên, quay video 3-5 phút và đóng ZIP sạch.

PHỤ LỤC A - KỊCH BẢN DEMO 3-5 PHÚT

12. 0:00-0:30: giới thiệu mục tiêu, kiến trúc và Swagger.
13. 0:30-1:00: init Vault, chứng minh init xong locked; unlock đúng/sai passphrase.
14. 1:00-1:40: register/login Alice và Bob; minh họa lockout hoặc nêu automated test.
15. 1:40-2:20: Alice write/read KV; mở DB chứng minh ciphertext; Bob bị PERMISSION_DENIED.
16. 2:20-3:10: create AES named key, encrypt/decrypt, tamper ciphertext và revoke key.
17. 3:10-4:10: create ED25519 key, RAW sign/verify; sửa message hoặc cross-key trả false; DIGEST đúng 32 byte.
18. 4:10-4:40: chạy pytest và chỉ ra 58 passed, coverage 96%.
19. 4:40-5:00: kết luận CIA, owner enforcement và key material không export.

PHỤ LỤC B - CHECKLIST NỘP BÀI

- Điền MSSV ba thành viên.
- Đổi tên report thành Report_MSSV1_MSSV2_MSSV3.pdf.
- Reset runtime data; không nộp .venv, cache, DB/config chứa secret.
- Đổi tên ZIP thành MSSV1_MSSV2_MSSV3.zip.
- Giải nén ZIP vào thư mục mới, cài requirements và chạy 58 tests.
- Đính kèm/đăng video demo 3-5 phút theo kênh nộp bài của giảng viên.